Access Rules (Roles & Employment Types)

This document describes **who can see and do what** in the application. Access is controlled by two independent user attributes:

1. **Role** (UserRole): SUPERADMIN, ADMIN, PROJECT_MANAGER, EMPLOYEE
2. **Employment type** (EmploymentType): INTERNAL or EXTERNAL

Both are defined in src/types.ts (User.role, User.employmentType). External users additionally carry companyName and externalType (PARTNER_EMPLOYEE | FREELANCER).

> Keep this document in sync when changing permission checks in the files referenced below.

---

1. How the effective role is determined

Rule	Where
A user is **Superadmin** if role === 'SUPERADMIN' **or** id === 'u-1' (hard-coded owner account).	server/storage.ts → getActorRoleInfo(); also NavigationSidebar.tsx, App.tsx
For non-superadmins the role is taken from the **membership of the currently active organisation** (user.memberships[].role), falling back to user.role.	server/storage.ts → getActorRoleInfo()
Role flags are exclusive: isAdmin (includes Superadmin) → isProjectManager → isEmployee.	server/storage.ts → getActorRoleInfo()
The acting user is identified via JWT (Authorization: Bearer …) or the x-user-id header.	server/http/session.ts → getActorId()

> **Note:** The frontend checks currentUser.role (global role), while the server uses the per-organisation membership role. For users with different roles per organisation, UI and server may disagree.

2. How the employment type is determined

Rule	Where
A user counts as **internal** if employmentType === 'INTERNAL', **or** if no employmentType and no companyName is set.	App.tsx, NavigationSidebar.tsx, BottomNavigationBar.tsx (isInternal)

Rule	Where
Everyone else (EXTERNAL, or a companyName is set) counts as **external** (freelancer / partner employee).	same

> **Note:** Memberships also store an employmentType per organisation, but the UI only evaluates the global user.employmentType.

3. Access matrix by role

Feature	SUPERADMIN	ADMIN	PROJECT_MANAGER	EMPLOYEE
Zeiterfassung (time tracking menu)	✅	✅	✅	✅
Book project time **for colleagues** (“Für Kollegen buchen”)	✅	✅	✅	❌
Employee filter in the project time list	✅	✅	✅	❌
See project time entries of others	✅ all	✅ all (active org)	✅ only on managed projects (+ own)	❌ own only
Employee selector in **Allg. Arbeitszeit**	✅	✅	❌	❌
See working time (Allg. Arbeitszeit) of others	✅	✅	❌ own only	❌ own only
Freigaben & Audit (approve / reject	✅	✅	✅ only managed projects	❌

Feature	SUPERADMIN	ADMIN	PROJECT_MANAGER	EMPLOYEE
entries)				
Audit log	✅ all orgs	✅ active org	own actions + managed projects	own actions
Projekte & Kunden	✅	✅	✅ only own projects (“Meine Projekte & Team”)	❌
Forecast	✅	✅	✅ only own projects (“Projekt-Forecast”)	❌ (own forecasts via API only)
Planned revenue / margin columns in Forecast & capacity views	✅[1]	✅	❌	❌
Cost rates of other employees	✅	✅	✅ unless project has allowPmViewCosts = false	❌
Exporte (XLSX)	✅ if internal	✅ if internal	✅ if internal	❌
Rates & Team (roles, rates, user management)	✅	✅	❌	❌
Clockify-Migration	✅	✅	❌	❌
API-Dokumentation / API keys	✅	✅	❌	❌
Switch user (act as another user)	✅	✅	❌	❌
Organisatio	✅	❌	❌	❌

Feature	SUPERADMIN	ADMIN	PROJECT_MANAGER	EMPLOYEE
nen (manage all tenants)				
Set / remove user passwords	✅	❌	❌	❌
Promote users to ADMIN / SUPERADMIN, edit Superadmins or other Admins	✅	❌	❌	❌

[1] ForecastView.tsx / EmployeeCapacityView.tsx gate these columns with canViewFinancials = role === 'SUPERADMIN' || role === 'ADMIN' || id === 'u-1', so Superadmins (incl. the built-in u-1) see them as well.

Projects visible to **employees** (for booking): projects they are assigned to (assignedUserIds / memberRates) plus all projects without restrictToAssignedMembers, excluding archived/completed projects and projects listing the user in excludedUserIds.

4. Access by employment type

Feature	INTERNAL	EXTERNAL (freelancer / partner)
Projektzeiterfassung	✅	✅
Allg. Arbeitszeit section (incl. Type selection: Regular / Vacation / Sick / Special leave / Parental leave)	✅	❌ (admins always see it)
Exporte menu (in addition to the role requirement)	✅	❌

Implementation: App.tsx renders ZeiterfassungView.tsx for the *Zeiterfassung* menu. There are no tabs anymore: for isAdmin || isInternal it shows one page with two separated sections — *Projektzeiterfassung* (TimeTrackerView) and, below a divider, *Allg. Arbeitszeit* (WorkingTimeView). External non-admins get only TimeTrackerView, without section headers. As a defensive second layer, WorkingTimeView.tsx computes isInternalUser = isAdmin || employmentType === 'INTERNAL' || (!employmentType && !companyName): the

Type selection is rendered only for internal users (admins always count as internal), and external non-admins get only a short notice instead of the view.

---

5. Server-side enforcement

Check	Where
/admin/* and /api/admin/* require ADMIN or SUPERADMIN	server/http/session.ts → requireAdminAuth; mounted in server/app.ts
POST /api/auth/switch-user → 403 for non-admins	server/app.ts
Set / delete passwords → 403 for non-superadmins	server/app.ts (/api/users/:id/password)
Role escalation to ADMIN/SUPERADMIN silently ignored for non-superadmins	server/storage.ts → updateUser()
Time entries filtered by role (PM: managed projects + own; employee: own)	server/storage.ts → getTimeEntries()
Working time: non-admins only see their own entries	server/storage.ts → getWorkingTimeEntries()
Approvals: employees cannot approve, PMs only managed projects	server/storage.ts → setApprovalStatus()
Projects / tasks / forecasts / audit logs filtered by role	server/storage.ts → getProjects(), getTasks(), getForecasts(), getAuditLogs()
XLSX exports require SUPERADMIN / ADMIN / PROJECT_MANAGER	server/app.ts → resolveExportActor()
External API (/api/v1/*) requires a valid API key	server/app.ts → requireApiKey

> **Gaps (UI-only rules, not enforced by the server):** - The *internal-only* restriction for **Exporte** is checked in the UI only; the export endpoints accept any ADMIN / PM regardless of employment type. - The *internal-only* restriction for **Allg. Arbeitszeit** is UI-only; the working-time API does not check employmentType.

6. Navigation visibility (quick reference)

Defined in src/components/NavigationSidebar.tsx (desktop) and src/components/BottomNavigationBar.tsx (mobile); views are additionally guarded in src/App.tsx.

Menu item	Visible when
Zeiterfassung	always
Freigaben & Audit	isAdmin || isPM
Projekte & Kunden	isAdmin || isPM
Forecast	isAdmin || isPM
Exporte	(isAdmin || isPM) && isInternal
Rates & Team	isAdmin
Clockify-Migration	isAdmin
API-Dokumentation	isAdmin
Organisationen	isSuperAdmin
Switch user (header menu)	isAdmin (Header.tsx)
Quick login on login page	only with URL parameter ?mode=admin (LoginView.tsx)